

CISSP Printable Practice Exam 06 - Domain 6 - Security Assessment and Testing

Domain 6

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-099)

Scenario: A regional payment processor is preparing to renew a major client contract. The internal security team designed and operates the controls protecting the service, and the client requires objective assurance about their effectiveness.

Which assessment approach would provide the MOST credible assurance to the client?

- A. Have the control owners complete a new self-assessment questionnaire.
- B. Assign an internal administrator to verify the configurations informally.
- C. Engage an independent qualified assessor to test the controls against an agreed scope.
- D. Ask the client to rely on the processor's existing security policies.

Question 2 (CISSP1-100)

Scenario: A security manager must plan an internal audit with limited staff. A customer portal processes sensitive records and has unresolved prior findings, while several low-impact internal tools have stable control histories.

What should the manager do FIRST when establishing the audit scope?

- A. Give every system equal testing time to demonstrate uniform treatment.
- B. Prioritize systems according to business impact, exposure, and unresolved findings.
- C. Limit the audit to controls that can be tested automatically.
- D. Exclude systems previously audited so the team can maximize new coverage.

Question 3 (CISSP1-101)

Scenario: During an internal audit, an auditor discovers that privileged access reviews are not being completed. The application owner asks the auditor to redesign and operate the review process before the final report is issued.

What is the auditor's BEST response?

- A. Design and operate the control so the finding can be closed immediately.
- B. Remove the finding because management has expressed an intent to remediate it.
- C. Describe the issue and criteria, while leaving control ownership and remediation to management.
- D. Delay all reporting until the application owner independently discovers the same issue.

Question 4 (CISSP1-102)

Scenario: A university has approved a third-party penetration test of its student services environment. Testing could affect shared infrastructure and systems managed by an external hosting provider.

Which TWO items should be formally established before active testing begins? Select 2 of the 5 options below.

- A. Written authorization and clearly defined rules of engagement.
- B. A guarantee that every vulnerability in the environment will be found.
- C. Scope boundaries, escalation contacts, and permitted testing windows.
- D. Immediate public disclosure of all discovered vulnerabilities.
- E. Permanent administrative credentials for every production system.

Question 5 (CISSP1-103)

Scenario: A cloud service provider supplies a report describing whether specified controls were suitably designed and operated effectively over a defined six-month period. A customer wants assurance covering its fiscal year and its own complementary controls.

What should the customer security manager do NEXT?

- A. Accept the report as proof that all customer responsibilities were performed.
- B. Confirm the report's scope and period, review exceptions, and evaluate complementary user-entity controls.
- C. Treat the report as a vulnerability scan of the provider's entire environment.
- D. Replace all internal vendor oversight with the provider's management assertion.

Question 6 (CISSP1-104)

Scenario: A regulated utility expects an external compliance audit shortly after its annual internal audit. Both engagements cover several of the same access-control processes, but the external auditor retains responsibility for its own conclusions.

Which strategy BEST reduces duplication while preserving assurance?

- A. Cancel the internal audit because the external audit will cover similar controls.
- B. Let the control owners choose which evidence the external auditor may see.
- C. Align schedules and evidence collection, document internal work quality, and allow the external auditor to determine reliance.
- D. Require the external auditor to adopt every internal conclusion without additional procedures.

Question 7 (CISSP1-105)

Scenario: An engineering firm has received a scanner report listing missing patches and insecure configurations. Leadership now wants to know whether an attacker could combine those weaknesses to reach restricted design files.

Which activity would BEST answer leadership's question?

- A. A penetration test with an authorized objective of reaching the restricted files.
- B. A second vulnerability scan using the same signatures.
- C. A policy review focused on patch-management documentation.
- D. A count of devices represented in the asset inventory.

Question 8 (CISSP1-106)

Scenario: A media company wants to determine why its monitoring rules miss certain credential-abuse behaviors. Leadership wants offensive testers and defenders to share observations during the exercise so detections can be tuned and retested immediately.

Which team structure BEST supports this objective?

- A. A red team operating without any defined scope or defender contact.
- B. A blue team reviewing alerts without simulated adversary activity.
- C. A purple-team exercise that coordinates offensive actions and defensive validation.
- D. An audit committee reviewing only the final annual metrics.

Question 9 (CISSP1-107)

Scenario: Before releasing a new claims application, a development security lead must identify unsafe code paths and also observe failures that appear only while the application is executing.

Which testing strategy provides the MOST complete coverage of these objectives?

- A. Use only static analysis because runtime behavior is outside the assessment scope.
- B. Combine static analysis of code with dynamic testing of the running application.
- C. Use only network discovery because it evaluates application logic directly.
- D. Review user training records instead of testing the application.

Question 10 (CISSP1-108)

Scenario: An online retailer must verify that a fraud control blocks a prohibited transaction pattern and that the attempted transaction creates the expected alert without using a real customer account.

Which TWO actions are MOST appropriate? Select 2 of the 5 options below.

- A. Execute a preauthorized synthetic transaction using a controlled test identity.
- B. Disable alerting during the test to prevent misleading evidence.
- C. Confirm the expected rejection and correlate the generated event with the security alert.
- D. Use an uninformed customer's account so the scenario appears realistic.
- E. Assume the control works because its configuration matches the documented standard.

Question 11 (CISSP1-109)

Scenario: A test report for a funds-transfer service shows full coverage of approved user workflows. It does not test malformed requests at an external interface or attempts by authorized users to exceed their transaction limits.

What is the MOST significant concern with the report?

- A. The testing omitted interface abuse and misuse cases, so stated coverage may overestimate assurance.
- B. The test team should have measured only the number of successful transactions.
- C. Approved workflow coverage makes negative testing unnecessary.
- D. The service cannot be tested until every possible input has been enumerated.

Question 12 (CISSP1-110)

Scenario: A manufacturing company plans recurring automated simulations of selected adversary techniques against production security controls. Operations leaders are concerned that the activity could interrupt industrial support services.

What is the BEST way to proceed?

- A. Run every available technique without notice to maximize realism.
- B. Define approved techniques, safety constraints, monitoring, and rollback procedures before execution.
- C. Replace the simulation with a review of written security policies only.
- D. Allow the simulation platform to expand its own scope whenever it finds a weakness.

Question 13 (CISSP1-111)

Scenario: An auditor is testing whether user access is removed promptly after employment termination. Human resources policy requires removal within one business day.

Which evidence would BEST demonstrate the control's operating effectiveness?

- A. A copy of the approved termination policy by itself.
- B. A sample linking termination timestamps to account-disablement records and documented exceptions.
- C. A current organizational chart showing reporting relationships.
- D. A statement from the help desk that requests are usually handled quickly.

Question 14 (CISSP1-112)

Scenario: A security steering committee reviews two monthly measures: the percentage of critical patches installed within the required service level and the number of internet-facing critical vulnerabilities older than that service level.

How should these measures be classified?

- A. Both are financial audit measures because they concern resource allocation.
- B. The installation percentage is a performance indicator, while the overdue exposure count is a risk indicator.
- C. The installation percentage is a risk indicator, while the overdue exposure count is a performance indicator.
- D. Neither is useful because security controls cannot be evaluated with metrics.

Question 15 (CISSP1-113)

Scenario: A hospital's backup dashboard shows that scheduled jobs completed successfully for the past quarter. The audit objective is to determine whether critical records can be recovered within approved recovery targets.

What additional evidence is MOST important?

- A. Documented restoration tests showing data integrity and recovery times for representative systems.
- B. The total storage capacity purchased for the backup environment.
- C. A list of employees permitted to view the backup dashboard.
- D. A vendor brochure describing general backup features.

Question 16 (CISSP1-114)

Scenario: A public agency reports that nearly all personnel completed annual security awareness training. The security manager must determine whether the program is improving recognition and reporting of suspicious messages.

Which TWO measures would provide the MOST useful evidence of effectiveness? Select 2 of the 5 options below.

- A. Results from controlled simulations, analyzed by role and trend over time.
- B. The number of training slides included in the annual course.
- C. Timeliness and quality of employee reports from simulations or validated events.
- D. The amount originally budgeted for training development.
- E. The seniority of the manager who approved the course.

Question 17 (CISSP1-115)

Scenario: A disaster recovery exercise missed the recovery time objective for two critical services. The test team found that an outdated dependency map caused the restoration sequence to fail, and service owners have proposed corrective actions.

Which reporting approach would BEST support management action?

- A. Report only that the exercise failed, without identifying affected objectives.
- B. List every test log entry chronologically and let executives determine significance.
- C. Describe the evidence, business impact, root cause, responsible owners, and time-bound remediation plan.
- D. Remove the result because corrective actions have already been proposed.

Question 18 (CISSP1-116)

Scenario: During a third-party audit, management approval records indicate that privileged accounts were reviewed quarterly. System logs for the same period suggest that several accounts remained active after their owners changed roles.

What should the audit lead do FIRST?

- A. Accept the approval records because signed evidence takes precedence over technical data.
- B. Conclude immediately that management intentionally falsified the records.
- C. Reconcile the populations and timestamps, obtain corroborating evidence, and expand the sample if warranted.
- D. Discard both sources and report that the control cannot be assessed.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-099) - Correct: C

An independent qualified assessor offers the strongest objectivity when external stakeholders need credible assurance. A self-assessment or informal administrator review lacks sufficient independence, while policies describe intended behavior but do not demonstrate operating effectiveness.

Question 2 (CISSP1-100) - Correct: B

A risk-based scope directs limited assurance resources toward the systems and controls whose failure would matter most. Equal allocation ignores differing risk, automation should not define scope, and prior audits do not justify excluding systems with significant or unresolved risk.

Question 3 (CISSP1-101) - Correct: C

The auditor should report the condition and preserve independence by leaving control design, ownership, and operation to management. Operating the control creates a self-review threat, management intent alone does not resolve the finding, and withholding a valid finding undermines the audit.

Question 4 (CISSP1-102) - Correct: A, C

Written authorization and rules of engagement establish legal and operational permission, while scope boundaries, contacts, and testing windows constrain risk and enable incident coordination. Complete discovery cannot be guaranteed, public disclosure is not a prerequisite, and unrestricted permanent credentials would create unnecessary exposure.

Question 5 (CISSP1-103) - Correct: B

Third-party assurance must be evaluated against the customer's required scope and period, including noted exceptions and complementary controls assigned to the customer. The report does not prove customer control performance, represent a universal vulnerability scan, or eliminate vendor oversight responsibilities.

Question 6 (CISSP1-104) - Correct: C

Coordinated scheduling and reusable, well-documented evidence can reduce burden, while the external auditor independently decides whether and how much to rely on internal work. Canceling internal assurance may leave governance gaps, selective evidence threatens completeness, and compulsory reliance undermines external independence.

Question 7 (CISSP1-105) - Correct: A

A penetration test attempts controlled exploitation and can demonstrate whether weaknesses can be chained to achieve the defined objective. A vulnerability scan identifies potential weaknesses but does not establish exploitability, while policy and inventory reviews address different assurance questions.

Question 8 (CISSP1-106) - Correct: C

A purple-team approach deliberately connects offensive techniques with defensive observation, tuning, and retesting. An isolated red or blue team provides only one side of the feedback loop, and an audit committee's metric review cannot reproduce or validate technical detection behavior.

Question 9 (CISSP1-107) - Correct: B

Static analysis can expose weaknesses in source or compiled code paths, while dynamic testing observes behavior in an executing application. Combining them addresses

complementary evidence needs. Network discovery does not directly evaluate application logic, and training records do not test software controls.

Question 10 (CISSP1-108) - Correct: A, C

A controlled synthetic transaction tests the business process without exposing a real customer, and correlating the outcome with the alert verifies both prevention and detection. Disabling alerting removes required evidence, using a customer account is inappropriate, and configuration conformity alone does not prove operational effectiveness.

Question 11 (CISSP1-109) - Correct: A

Coverage of normal workflows does not demonstrate resilience against malformed interface input or authorized-user misuse. Transaction counts alone do not address negative paths, approved flows do not replace misuse testing, and exhaustive enumeration of every input is neither necessary nor practical for risk-based assurance.

Question 12 (CISSP1-110) - Correct: B

Threat-informed simulation can validate controls repeatedly, but production use requires explicit scope, safeguards, observation, and recovery procedures. Unrestricted or self-expanding tests create unacceptable operational risk, while policy review alone cannot demonstrate how technical controls respond to simulated techniques.

Question 13 (CISSP1-111) - Correct: B

Timestamped records matched across the triggering and deprovisioning processes provide evidence that the control operated within the required period, while exceptions reveal failures. Policy proves design intent, and an organizational chart or general statement does not substantiate actual performance.

Question 14 (CISSP1-112) - Correct: B

The installation percentage measures how well the patching process meets its target, making it a key performance indicator. The count of overdue exposed vulnerabilities signals current risk exposure, making it a key risk indicator. Both measures can support control assessment when definitions and data quality are sound.

Question 15 (CISSP1-113) - Correct: A

Successful job status shows that backup operations ran, but restoration testing demonstrates recoverability, integrity, and alignment with recovery targets. Capacity and dashboard access may matter to other controls, while marketing material provides no evidence that this organization's data can be restored.

Question 16 (CISSP1-114) - Correct: A, C

Simulation results and the timeliness and quality of reporting measure observable behavior tied to the program's objective. Slide count, budget, and approver seniority are administrative facts that do not show whether personnel can recognize and report suspicious activity effectively.

Question 17 (CISSP1-115) - Correct: C

An actionable report connects verified evidence to business impact and root cause, then identifies accountability and remediation timing. A bare failure statement lacks decision context, raw logs overwhelm the audience, and a proposed action does not erase the observed control deficiency.

Question 18 (CISSP1-116) - Correct: C

Contradictory evidence should be reconciled by validating scope, timing, and data sources,

then gathering corroboration and extending testing as risk warrants. Neither signed records nor logs should be accepted uncritically, intent should not be inferred without evidence, and the discrepancy itself justifies further assessment rather than abandonment.